

ETHICAL HACKING

ACTIVIDAD 01. ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Nombre: Brenda Joseline Valdez Rojas

Fecha de entrega: 5 de septiembre

1.



OBJETIVO DEL PENTEST

Define 3 objetivos concretos que tendría la evaluación de seguridad de Aurora Market

Objetivo 1	Identificar vulnerabilidades de seguridad en la aplicación web de Aurora Market, especialmente aquellas relacionadas con autenticación, autorización, gestión de sesiones y control de acceso entre cuentas de usuarios. Esto conecta directamente con el incidente reportado: un usuario aparentemente visualizó información perteneciente a otra cuenta.
Objetivo 2	Determinar si las vulnerabilidades identificadas pueden ser explotadas y evaluar su impacto real sobre la confidencialidad, integridad y disponibilidad de la información de Aurora Market. Aquí no basta con decir “hay un fallo”; el pentest debe ayudar a determinar qué podría conseguir realmente un atacante.
Objetivo 3	Proporcionar a Aurora Market hallazgos documentados, priorizados por riesgo y acompañados de recomendaciones de mitigación, para reducir la exposición de la aplicación y proteger los datos de sus clientes. OWASP subraya precisamente que los resultados deben ser accionables, explicar impacto, causa y medidas correctivas, no limitarse a listar vulnerabilidades.

2.



ALCANCE

Identifica claramente qué se evaluará y qué queda fuera del alcance.

SÍ SE EVALUARA

Sistemas o elementos incluidos en el alcance

- Aplicación web autorizada de Aurora Market.
- Funciones accesibles para clientes: registro, inicio de sesión, catálogo, carrito, compras y consulta de pedidos.
- Mecanismos de autenticación, gestión de sesiones y autorización.
- Controles de acceso entre distintos usuarios y roles.
- Área administrativa de la aplicación, únicamente en la medida en que esté incluida expresamente en la autorización y puedan realizarse pruebas sin afectar información real.

FUERA DEL ALCANCE

Elementos que no serán evaluados

- Redes sociales de Aurora Market.
- Equipos personales o corporativos de los empleados.
- Cuentas de correo electrónico.
- Proveedores y servicios externos.
- Otros sistemas o infraestructura no incluidos expresamente en la autorización.
- Ingeniería social contra empleados o clientes, salvo autorización específica.

3.



AUTORIZACIÓN Y CONDICIONES

Explica qué permisos y condiciones deben estar definidos antes de comenzar las pruebas.

PERMISOS REQUERIDOS

- Autorización formal y por escrito de Aurora Market para realizar el pentest.
- Identificación exacta de la aplicación, dominio, URL, APIs o componentes autorizados.
- Definición de los tipos de pruebas permitidos y prohibidos.
- Credenciales o cuentas de prueba, si Aurora Market decide proporcionarlas.
- Autorización específica para probar diferentes roles y controles de acceso.
- Designación de un contacto responsable de Aurora Market durante las pruebas.

CONDICIONES ACORDADAS

- Realizar pruebas únicamente sobre los activos incluidos en el alcance.
- Trabajar preferentemente en horarios de menor actividad.
- No provocar interrupciones deliberadas del servicio.
- No alterar, eliminar o comprometer información real de clientes.
- Evitar acciones destructivas o pruebas de denegación de servicio.
- Documentar cuidadosamente las vulnerabilidades y evidencias encontradas.
- Detener o escalar inmediatamente cualquier prueba que genere riesgo inesperado.
- Mantener la confidencialidad de toda la información obtenida durante el pentest.
- Definir previamente un procedimiento de emergencia y contacto en caso de detectar una vulnerabilidad crítica o provocar accidentalmente un impacto en producción.

4.



TIPO DE PENTEST

Determina si el escenario corresponde a un: Black-box, Gray-box o White box. Investiga brevemente el concepto y justifica tu elección.

TIPO DE PENTEST ELEGIDO: Gray-Box



BLACK-BOX

El evaluador no tiene conocimiento previo de la infraestructura, código o configuraciones.



GRAY-BOX

El evaluador tiene información parcial, como credenciales o datos de la aplicación, pero no conoce todos los detalles internos.



WHITE-BOX

El evaluador tiene conocimiento completo de la infraestructura, código fuente y configuraciones.



JUSTIFICACIÓN DE LA ELECCIÓN

El pentest de Aurora Market corresponde a un enfoque Gray-box porque el equipo dispone de información parcial sobre el sistema. Conoce la existencia de la aplicación web, una base de datos, mecanismos de autenticación y diferentes tipos de usuarios, pero no dispone de información completa sobre la arquitectura, tecnologías, código fuente o configuraciones internas. Por tanto, la evaluación combina conocimiento previo limitado con técnicas de descubrimiento propias de una evaluación externa.

5.



PLANIFICACIÓN

Establece qué debería hacer el equipo antes de comenzar la parte técnica.
Completa elementos clave.

OBJETIVOS	Identificar vulnerabilidades, comprobar su impacto y proponer medidas correctivas.
ALCANCE	Aplicación web autorizada, funcionalidades de usuario, autenticación, sesiones y controles de acceso.
PERMISOS Y CONDICIONES	Autorización escrita, activos autorizados, horarios, pruebas permitidas y restricciones.
METODOLOGIA A UTILIZAR	OWASP Web Security Testing Guide, complementado con un proceso estructurado de pentesting.
RECOPIACIÓN DE INFORMACIÓN PREVIA	URLs, roles, cuentas de prueba, funcionalidades, tecnologías conocidas y antecedentes del incidente.
RECURSOS NECESARIOS	Equipo de pentesting, navegador, proxy de análisis web, herramientas de enumeración y documentación.
PROGRAMACIÓN DEL PENTEST	Realizar las pruebas en horarios de baja actividad y establecer ventanas de trabajo y comunicación.

6.



FASES DEL PENTEST

Explica cómo aplicarías cada fase al caso de Aurora Market. ¿Qué buscarías hacer en cada etapa?

RECONOCIMIENTO	Recopilar información sobre la aplicación web, identificar tecnologías utilizadas, funcionalidades disponibles, puntos de entrada, tipos de usuario, mecanismos de autenticación y superficie de ataque, siempre dentro del alcance autorizado. Ejemplos: - páginas y rutas; - formularios; - parámetros; - endpoints; - proceso de login; - recuperación de contraseña, etc.
ANÁLISIS DE VULNERABILIDADES	Analizar los componentes identificados para detectar posibles debilidades en autenticación, autorización, sesiones, validación de entradas, configuración y lógica de negocio. Prestando atención a: - Broken Access Control; - posibles IDOR; - autenticación; - sesiones; - escalada de privilegios; - exposición de información; - inyecciones; - XSS; - configuraciones inseguras; - lógica de compra/pedidos.
EXPLOTACIÓN	Intentar reproducir de forma controlada las vulnerabilidades identificadas para confirmar si son explotables y determinar qué impacto tendría un atacante real. Por ejemplo, comprobar de forma controlada si un usuario autorizado puede acceder a recursos pertenecientes a otra cuenta modificando identificadores o solicitudes, utilizando exclusivamente cuentas y datos de prueba autorizados.
POST-EXPLOTACIÓN	Determinar de manera limitada qué nivel de acceso o impacto podría alcanzarse después de explotar una vulnerabilidad, sin comprometer información real ni afectar el funcionamiento de la plataforma. ¿permite acceder únicamente a un pedido ajeno? ¿permite acceder sistemáticamente a múltiples cuentas? ¿permite escalar de usuario cliente a administrador? ¿permite modificar información además de visualizarla?

INFORME	Documentar las vulnerabilidades encontradas, evidencia de su reproducción, activos afectados, nivel de riesgo, impacto potencial y recomendaciones concretas para su corrección. Así como también me enfocaría en clasificar los hallazgos por severidad y distinguir entre resumen ejecutivo y detalle técnico.
----------------	--



INVESTIGACIÓN

Consulta al menos una de las metodologías que revisamos en clase y explica por qué podría ser útil para este proyecto.

METODOLOGÍA ELEGIDA
OWASP Web Security Testing Guide
¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?
La metodología OWASP WSTG es especialmente adecuada para Aurora Market porque está diseñada específicamente para evaluar la seguridad de aplicaciones y servicios web. Proporciona pruebas estructuradas para áreas como recopilación de información, configuración, autenticación, autorización, gestión de sesiones, validación de entradas, lógica de negocio y seguridad del lado del cliente. Estas áreas coinciden directamente con los riesgos presentes en Aurora Market, particularmente con el posible acceso de un usuario a información perteneciente a otra cuenta. Además, facilita una evaluación sistemática y reproducible y permite documentar los hallazgos de forma clara y accionable. OWASP define WSTG como un marco abierto y mantenido por la comunidad para probar aplicaciones y servicios web, y su cobertura encaja casi exactamente con el caso que nos plantean.